
2. Review & Analyze Requirements

2.1 Introduction to Requirement Analysis

Requirement analysis is a critical phase in the Software Testing Life Cycle (STLC) where the testing team studies the application in detail to understand its functionality, behavior, and security expectations. In security testing projects, requirement analysis focuses on identifying potential vulnerabilities, attack surfaces, and security controls within the application.

For this project, the application under test is the **OWASP Juice Shop Web Application**, which is intentionally designed with multiple security vulnerabilities for training and testing purposes.

The requirement analysis phase helps in identifying what needs to be tested, how it should be tested, and which security risks must be validated through test scenarios and automation scripts.

2.2 Objective of Requirement Analysis

The main objectives of requirement analysis in this project are:

- To understand the functional and non-functional behavior of the OWASP Juice Shop application
 - To identify security-sensitive areas in the application
 - To determine possible attack vectors such as input fields, login forms, and feedback forms
 - To analyze how user input is processed by the system
 - To define testable security requirements
 - To map requirements with potential vulnerabilities such as SQL Injection and XSS
 - To prepare a foundation for designing test scenarios and automation scripts
-

2.3 Understanding the Application Requirements

The OWASP Juice Shop application provides several functional modules that are relevant for security testing. These include:

1. Authentication Module

This module handles user login and session management. It is a critical area for security testing because improper validation can lead to unauthorized access.

Key observations:

- Login form accepts username and password inputs
 - No strict validation against malicious input is enforced in vulnerable scenarios
 - Session handling is required after successful authentication
-

2. Feedback / Contact Module

This module allows users to submit comments or feedback.

Key observations:

- Accepts free-text input from users
 - Input is directly processed and rendered
 - High risk area for Cross-Site Scripting (XSS) attacks
 - Requires proper input sanitization and encoding
-

3. Input Fields Across Application

Multiple input fields exist across the application such as search bars, login forms, and feedback forms.

Key observations:

- Inputs are not strongly validated
 - User input may be directly processed by backend systems
 - High risk of SQL Injection and input manipulation attacks
-

4. Session Management

Session handling is used to maintain user state after login.

Key observations:

- Session should be invalidated after logout
 - Unauthorized access should be blocked after session termination
 - Browser back navigation should not restore protected pages
-

5. Error Handling Mechanism

Error handling is required to manage invalid inputs and system failures.

Key observations:

- Application may expose internal system errors in some cases
 - Secure applications should display generic error messages only
 - Stack traces or database errors should not be visible to users
-

2.4 Identified Security Requirements

Based on analysis of the application, the following security requirements were identified:

1. Input Validation Requirement

- Application must validate all user inputs
 - Malicious payloads must be rejected
 - Special characters must be sanitized
-

2. Authentication Security Requirement

- Only valid users should be allowed to log in
 - Invalid credentials must be rejected
 - Unauthorized users should not access restricted pages
-

3. XSS Protection Requirement

- User input should be encoded before rendering
 - Script tags and event-based payloads must not execute
 - Application must prevent stored and reflected XSS attacks
-

4. SQL Injection Protection Requirement

- Input fields must not allow execution of SQL commands

- Database queries must be parameterized
 - Malicious SQL payloads must not expose sensitive data
-

5. Session Security Requirement

- Session must expire after logout
 - User should not access protected pages after logout
 - Session tokens must be invalidated properly
-

6. Error Handling Requirement

- Application must not expose internal errors
 - Error messages should be user-friendly
 - No database or stack trace information should be visible
-

2.5 Risk Identification

During requirement analysis, the following security risks were identified:

- Injection vulnerabilities in input fields
- Cross-Site Scripting due to unsafe rendering
- Weak authentication validation
- Improper session invalidation
- Exposure of internal system errors
- Lack of input sanitization

These risks directly influenced the design of test scenarios and automation scripts.

2.6 Requirement Traceability Preparation

Each identified requirement is mapped to test scenarios in later phases using the Requirement Traceability Matrix (RTM). This ensures:

- Every requirement has corresponding test coverage
 - No security requirement is left untested
 - Test cases are aligned with business and security objectives
-

2.7 Outcome of Requirement Analysis

After completing this phase, the following outputs were achieved:

- Identification of critical security-sensitive modules
 - Definition of security requirements
 - Understanding of application attack surface
 - Input for designing test scenarios and test cases
 - Foundation for automation framework development
-

2.8 Conclusion

Requirement analysis provided a clear understanding of the OWASP Juice Shop application from a security testing perspective. It helped in identifying vulnerable areas and defining structured security requirements.

This phase ensured that the testing process is systematic, traceable, and aligned with real-world security testing standards.
